

mongodb未授权访问漏洞

笔记本：应用服务加固

创建时间：2018/11/2 21:26

更新时间：2018/11/3 21:45

作者：苏醒

URL：<https://www.cnblogs.com/yanwanglol/p/8762663.html>

atalogue

1. mongodb安装
2. 未授权访问漏洞
3. 漏洞修复及加固
4. 自动化检测点

1. mongodb安装

如果没有MongoDB的源，则进行添加，vi /etc/yum.repos.d/mongodb-org-3.2.repo

```
[mongodb-org-3.2]
name=MongoDB Repository
baseurl=https://repo.mongodb.org/yum/redhat/\$releasever/mongodb-org/3.2/x86\_64/
gpgcheck=1
enabled=1
```

gpgkey=<https://www.mongodb.org/static/pgp/server-3.2.asc>

2.安装MongoDB

```
yum -y install mongodb-org
```

0x1: 创建数据库目录

MongoDB的数据存储在data目录的db目录下，但是这个目录在安装过程不会自动创建，所以你需要手动创建data目录，并在data目录中创建db目录。/data/db 是 MongoDB 默认的启动的数据库路径(--dbpath)

```
mkdir -p /data/db
```

0x2: 命令行中运行 MongoDB 服务

mongod

后台启动

```
mongod --dbpath=/data/db --fork --logpath=/data/logs
```

0x3: MongoDB后台管理 Shell

如果你需要进入MongoDB后台管理，你需要先打开mongodb装目录的下的bin目录，然后执行mongo命令文件。MongoDB Shell是MongoDB自带的交互式Javascript shell,用来对MongoDB进行操作和管理的交互式环境。当你进入mongoDB后台后，它默认会链接到 test 文档(数据库)



```
root@iz23und3yqhZ:~# mongo
MongoDB shell version: 2.4.9
connecting to: test
Welcome to the MongoDB shell.
For interactive help, type "help".
For more comprehensive documentation, see
```

```
http://docs.mongodb.org/  
Questions? Try the support group  
http://groups.google.com/group/mongodb-user  
>  

```

现在让我们插入一些简单的数据，并对插入的数据进行检索

```
> db.runoob.insert({x:10})  
> db.runoob.find()  
{ "_id" : ObjectId("586df25ead93a0064a40a3ae"), "x" : 10 }  
>
```

0x4: MongoDB web 用户界面

MongoDB 提供了简单的 HTTP 用户界面。如果你想启用该功能，需要在启动的时候指定参数 `--rest`

```
./mongod --dbpath=/data/db --rest
```

MongoDB 的 Web 界面访问端口比服务的端口多1000

如果你的MongoDB运行端口使用默认的27017，你可以在端口号为28017访问web用户界面，即地址为：

<http://localhost:28017>

Relevant Link:

```
http://www.runoob.com/mongodb/mongodb-linux-install.html
```

2. 未授权访问漏洞

开启MongoDB服务时不添加任何参数时,默认是没有权限验证的,登录的用户可以通过默认端口无需密码对数据库任意操作(增删改高危动作)而且可以远程访问数据库

0x1: 漏洞成因

在刚安装完毕的时候MongoDB都默认有一个admin数据库,此时admin数据库是空的,没有记录权限相关的信息!当admin.system.users一个用户都没有时,即使mongod启动时添加了一auth参数,如果没有在admin数据库中添加用户,此时不进行任何认证还是可以做任何操作(不管是否是以一auth 参数启动),直到在admin.system.users中添加了一个用户。加固的核心是只有在admin.system.users中添加用户之后, mongodb的认证,授权服务才能生效

Relevant Link:

```
https://www.secpulse.com/archives/27090.html  
http://websec.360.cn/vul/view/vulid/3558
```

3. 漏洞修复及加固

0x1: 修改默认端口

修改默认的mongoDB端口(默认为: TCP 27017)为其他端口

0x2: 不要开放到公网0.0.0.0

```
vim /etc/mongodb.conf  
bind_ip = 127.0.0.1
```

和redis一样，mongodb最好只开放本地监听，至少不能是0.0.0.0

0x3: 禁用HTTP和REST端口

MongoDB自身带有一个HTTP服务和并支持REST接口。在2.6以后这些接口默认是关闭的。mongoDB默认会使用默认端口监听web服务，一般不需要通过web方式进行远程管理，建议禁用。修改配置文件或在启动的时候选择`nohttpinterface` 参数`nohttpinterface = false`

0x4: 开启日志审计功能

审计功能可以用来记录用户对数据库的所有相关操作。这些记录可以让系统管理员在需要的时候分析数据库在什么时段发生了什么事情

0x5: 开启MongoDB授权

在admin 数据库中创建用户，如 supper 密码为 sup(此处均为举例说明，请勿使用此账号密码)



```
> use admin
switched to db admin
> db.addUser("supper", "sup")
{
  "user" : "supper",
  "readOnly" : false,
  "pwd" : "f4e451395b5b554788c796e5488573b2",
  "_id" : ObjectId("586dfb12ad93a0064a40a3af")
}
> db.auth("supper", "sup")
1
> exit
bye
```



修改配置文件

```
vim /etc/mongodb.conf
auth = true
```

Relevant Link:

```
https://laravel-china.org/topics/328
https://help.aliyun.com/knowledge_detail/37451.html
```

4. 自动化检测点

0x1: 检测是否监听到127.0.0.1

不管是配置文件里的，还是命令行参数里的，只要最终结果不是127.0.0.1，就认为是不安全的

```
--bind_ip 127.0.0.1
or
vim /etc/mongodb.conf
bind_ip = 127.0.0.1
```

0x2: 检测是否开启auth认证

```
mongod --auth  
or  
vim /etc/mongodb.conf  
auth = true
```

Copyright (c) 2016 LittleHann All rights reserved